

Circular 2025/06 — Cryptographic Standards and Quantum-Resistant Encryption Requirements

Reference:	FRA/CIR/2025/006	Issue Date:	25 February 2025
Effective Date:	01 September 2025	Response Deadline:	30 June 2025
Issuing Authority:	Financial Regulatory Authority	Classification:	MANDATORY

1. Background

In response to the increasing threat posed by quantum computing to current cryptographic standards, the Authority is issuing binding requirements for the adoption of post-quantum cryptographic algorithms. All regulated firms must begin transitioning away from RSA and elliptic curve cryptography for the protection of sensitive data with long confidentiality requirements. This circular sets a firm transition timeline effective 1 September 2025.

2. Prohibited Cryptographic Standards

With effect from 1 September 2025, the following cryptographic algorithms are PROHIBITED for the protection of client data, transaction records and inter-system communications: (a) RSA with key lengths below 4096 bits; (b) Elliptic Curve Diffie-Hellman (ECDH) curves below 384 bits; (c) SHA-1 and MD5 for any security purpose; (d) DES and 3DES in all forms; (e) TLS versions 1.0 and 1.1. Firms must complete a full cryptographic inventory by 30 June 2025.

3. Mandatory Post-Quantum Standards

Firms must implement NIST-approved post-quantum cryptographic algorithms for all new system developments from 1 March 2025. For existing systems, firms must present a transition roadmap by 30 June 2025 with milestones for full post-quantum adoption by 31 December 2027. Mandatory algorithms include: CRYSTALS-Kyber for key encapsulation and CRYSTALS-Dilithium for digital signatures, as standardised in NIST FIPS 203 and FIPS 204 respectively.

4. Certificate Management

All public-key infrastructure (PKI) certificates used for client-facing services must be issued by a Certificate Authority recognised by the Authority. Certificate validity periods must not exceed 398 days. Firms must implement automated certificate lifecycle management to prevent expiry-related service outages. A certificate inventory must be submitted to the Authority by 30 April 2025.

5. Incident Notification

Any cryptographic failure or compromise of private keys must be reported to the Authority within 2 hours of discovery. Firms must have a documented key compromise response procedure that has been tested within the last 12 months. The procedure must include immediate certificate revocation, re-issuance and notification to affected clients within 24 hours.